

חקירת URLs חשודים — כלי CLI וכלי OSINT

פישנינג ואבטחת מייל — שימוש ב-VirusTotal, curl, whois, dig, urlscan.io

מטרות המעבדה

- חקירת URLs חשודים באמצעות `dig`, `curl` ו-`whois`
- שימוש ב-urlscan.io לסריקת URL וקבלת screenshot
- שימוש ב-VirusTotal לבדיקת URL מול מנועי AV מרובים
- Defanging של IOCs — המרת URLs ו-IPs לפורמט בטוח
- כתיבת דוח IOC מקצועי
- בניית סקריפט Python לחקירת URL אוטומטית

דרישות מקדימות

- מחשב עם Windows / Linux / macOS
- כלי (Linux/macOS) `curl`, `whois` CLI או (Windows) `nslookup`
- חשבון חינמי ב-urlscan.io
- חשבון חינמי ב-VirusTotal
- Python 3.x מותקן (אופציונלי)
- Notepad++ או כל עורך טקסט

אזהרת בטיחות

חשוב מאוד: במעבדה זו נחקור URLs חשודים. כללי בטיחות:

- לעולם אל תפתחו URL חשוד ישירות בדפדפן!
- השתמשו רק ב-`curl -Is` (headers בלבד) או בכלי מקוונים
- אם תרצו לפתוח URL — עשו זאת רק ב-VM מבודדת

- תמיד Defang את ה-URLs לפני שיתוף (//:https //:hxxps במקום)

חלק א — חקירת URL עם curl

שלב 1

השתמשו ב- `curl` לבדיקת ה-HTTP headers של URL חשוד **בלי לטעון את התוכן**:

```
# בלבד headers בדיקת (-I = HEAD request, -s = silent)
curl -Is https://example.com

# תוצאה צפויה:
HTTP/2 200
content-type: text/html; charset=UTF-8
server: ECAcc (dce/26C5)
x-cache: HIT
content-length: 1256
date: Tue, 15 Apr 2026 09:30:00 GMT
```

שימו לב לפרטים הבאים:

- **Status Code:** 200 = OK, 301/302 = Redirect, 403 = Forbidden, 404 = Not Found
- **Server:** מזהה את סוג השרת (Apache, nginx, IIS)
- **Content-Type:** סוג התוכן (text/html, application/pdf)
- **Location:** אם יש redirect — לאן?

שלב 2

בדקו Redirect Chain — עקבו אחרי הפניות אוטומטיות:

```
# redirects (-L) והצג את כל ה-headers (-v)
curl -IsL https://bit.ly/example-shortened-url 2>&1 | grep -E "(HTTP/|Loca

# תוצאה לדוגמה:
HTTP/2 301
Location: https://suspicious-redirect.com/step1
HTTP/2 302
```

Location: https://evil-phishing-site.com/login.html
HTTP/2 200

URL מקוצר שמבצע מספר redirects הוא סימן חשוד! תוקפים משתמשים ב-redirect chains להסתרת היעד האמיתי.

שלב 3

בדקו את תעודת ה-SSL של האתר:

```
# הצגת פרטי SSL certificate
curl -vI https://suspicious-site.com 2>&1 | grep -E "(subject:|issuer:|exp

# תוצאה לדוגמה (אתר פישניג):
* subject: CN=suspicious-site.com
* issuer: C=US; O=Let's Encrypt; CN=R3
* expire date: Apr 20 2026 00:00:00 GMT

# לעומת אתר לגיטימי:
* subject: CN=www.paypal.com
* issuer: C=US; O=DigiCert Inc; CN=DigiCert SHA2 Extended Validation Serve
* expire date: Jan 15 2027 00:00:00 GMT
```

נקודות לבדיקה:

○ **Issuer:** Let's Encrypt (חינמי) לעומת DigiCert/Comodo (בתשלום, EV)

○ **Subject:** האם הדומיין תואם למה שציפיתם?

○ **Expiration:** תעודה שפגה = אתר לא מתוחזק

אתרי פישניג רבים משתמשים ב-Let's Encrypt כי הוא חינמי ומהיר. זה לא אומר שכל Let's Encrypt זדוני, אבל זה גורם נוסף לבדיקה.

שלב 4

בדקו את תוכן HTML של דף חשוד (בזהירות!):

```
# לקובץ לניתוח (בלי לפתוח בדפדפן!) HTML הורדת
curl -s https://suspicious-site.com/login.html -o suspicious_page.html

# credential harvesting חיפוש סימני
grep -i "password\\|passwd\\|login\\|credentials\\|form action" suspicious_page.html

# חיצוני JavaScript חיפוש
grep -oP 'src="[^"]*"' suspicious_page.html

# (לאן הנתונים נשלחים) form action חיפוש
grep -oP 'action="[^"]*"' suspicious_page.html
```

אל תפתחו את suspicious_page.html בדפדפן! נתחו אותו רק בעורך טקסט.

חלק ב — חקירת DNS ו-WHOIS

שלב 1

בדקו את ה-DNS records של הדומיין החשוד:

```
# A Record – כתובת IP
nslookup suspicious-site.com
# או:
dig A suspicious-site.com +short

# תוצאה לדוגמה:
185.234.72.19

# MX Records – שרתי מייל
nslookup -type=MX suspicious-site.com

# NS Records – שרתי DNS
nslookup -type=NS suspicious-site.com
```

```
# TXT Records – SPF, DKIM, site verification
nslookup -type=TXT suspicious-site.com
```

שלב 2

בצעו **Reverse DNS Lookup** — מי מחזיק את ה-IP?

```
# Reverse DNS
nslookup 185.234.72.19

# dig (Linux/macOS)
dig -x 185.234.72.19 +short

# תוצאה לדוגמה:
server1.cheap-hosting-provider.ru
```

אם ה-Reverse DNS מצביע על ספק hosting זול ברוסיה/אוקראינה — זה מגביר את החשד.

שלב 3

בצעו **WHOIS Lookup** — מי רשם את הדומיין?

```
# WHOIS (Linux/macOS)
whois suspicious-site.com

# Windows – השתמשו ב-:
# https://whois.domaintools.com/suspicious-site.com
```

שימו לב לפרטים הבאים:

```
Domain Name: suspicious-site.com
Registry Domain ID: 2789456123_DOMAIN_COM-VRSN
Registrar: NameCheap, Inc.
Updated Date: 2026-04-10T08:00:00Z
Creation Date: 2026-04-09T22:15:00Z ← נרשם אתמול!
Registrar Registration Expiration Date: 2027-04-09
```

Registrant Organization: WhoisGuard, Inc. ← הסתרת זהות!

Registrant Country: PA ← פנמה

דגלים אדומים ב-WHOIS:

- דומיין שנרשם לאחרונה (Creation Date = ימים ספורים) — דומיינים לגיטימיים בדרך כלל ותיקים
- WhoisGuard / Privacy Protection — הסתרת זהות הרושם
- Registrar זול (NameCheap, Porkbun) — לא סימן ודאי אבל גורם נוסף
- תוקף קצר (שנה אחת בלבד)

שלב 4

בדקו **Domain Age** — כמה זמן הדומיין קיים:

WHOIS-חישוב גיל דומיין מ

Creation Date: 2026-04-09 → 6 ימים! גיל:

להשוואה - דומיין לגיטימי:

whois google.com

Creation Date: 1997-09-15 → 29~ שנים! גיל:

דומיין בן פחות מ-30 יום חשוד מאוד. רוב דומיינים זדוניים נוצרים ימים ספורים לפני הקמפיין.

חלק ג — urlscan.io — סריקת URL מקוונת

שלב 1

פתחו את urlscan.io בדפדפן.

הכניסו את ה-URL החשוד בשורת החיפוש ולחצו **Scan**.

בחרו **Unlisted** visibility: (לא פומבי) או **Private** (עם חשבון Pro).

שימו לב: סריקה Public חושפת את ה-URL ברשימות ציבוריות. אם זה חקירה רגישה — בחרו **Unlisted**!

שלב 2

לאחר הסריקה (30-60 שניות), בחנו את התוצאות:

:Summary

Overall verdict: Potentially malicious (Score: 85/100)

Page URL: <https://login-verify-acc0unt.com/auth/microsoft.html>
Final URL: <https://login-verify-acc0unt.com/auth/microsoft.html> (no r
IP: 185.234.72.19
ASN: AS48693 – Rices Privately owned enterprise
Server: nginx/1.18.0
Country: UA (Ukraine)
Page title: "Sign in to your Microsoft account"
TLS Issuer: Let's Encrypt Authority X3

כותרת הדף מתחזה ל-Microsoft, השרת באוקראינה, דומיין חדש — פשינג כמעט ודאי!

שלב 3

בחנו את urlscan.io — **Screenshot** מצלם את הדף:

בדקו:

- האם הדף מתחזה למותג מוכר (Microsoft, Google, PayPal)?
- האם יש טופס login?
- האם יש לוגו מזויף?
- האם ה-URL בדפדפן תואם למה שציפיתם?

שלב 4

בחנו את **HTTP Transactions** — כל הבקשות שהדף ביצע:

Request log:

1. GET /auth/microsoft.html → 200 OK (text/html)
2. GET /assets/css/style.css → 200 OK (text/css)
3. GET /assets/img/microsoft-logo.png → 200 OK (image/png)

4. POST /api/collect.php → 200 OK (application/json) ← !
5. GET https://fonts.googleapis.com/ ... → 200 OK

שורה 4 חשובה: `POST /api/collect.php` — כאן הנתונים (סיסמאות!) נשלחים לשרת התוקף!

שלב 5

בחנו את **DOM Content** — תוכן ה-HTML של הדף:

urlscan.io מציג את ה-DOM המלא. חפשו:

```
# חפשו form action
<form action="/api/collect.php" method="POST">

# חפשו hidden fields
<input type="hidden" name="campaign" value="ms-april-2026">

# חפשו JavaScript collectors
<script>
  document.getElementById('loginForm').addEventListener('submit', function() {
    var data = { email: document.getElementById('email').value,
                  password: document.getElementById('password').value };
    fetch('/api/collect.php', { method: 'POST', body: JSON.stringify(data) });
  });
</script>
```

שלב 6

השתמשו ב-API של **urlscan.io** לסריקה אוטומטית (אופציונלי):

```
# API דרך URL סריקת
curl -X POST "https://urlscan.io/api/v1/scan/" \
  -H "API-Key: YOUR-API-KEY" \
  -H "Content-Type: application/json" \
  -d '{"url": "https://suspicious-site.com", "visibility": "unlisted"}'
```



```
# תוצאה:
{
  "uuid": "abc123-def456- ... ",
  "result": "https://urlscan.io/result/abc123-def456- ... /"
}

# קבלת תוצאות (לאחר 30 שניות)
curl "https://urlscan.io/api/v1/result/abc123-def456- ... /"
```

חלק ד — VirusTotal — בדיקת URL מול מנועי AV

שלב 1

פתחו את [VirusTotal](#).

בחרו לשונית **URL** והכניסו את ה-URL החשוד.

לחצו Enter או על כפתור החיפוש.

שלב 2

בחנו את תוצאות הסריקה:

Detection: 12/94 security vendors flagged this URL as malicious

Vendors detecting:

- Fortinet: Phishing
- Kaspersky: Phishing
- BitDefender: Phishing
- ESET: Phishing
- Sophos: Malware
- Avira: Phishing
- Google Safe Browsing: Phishing
- Netcraft: Malicious
- Phishtank: Phishing
- OpenPhish: Phishing
- CRDF: Malicious
- Fortinet: Phishing

Community Score: -15 (negative = likely malicious)

12 מתוך 94 מנועים זיהו את ה-URL כפיישינג — זהו אישור חזק שמדובר באתר זדוני.

שלב 3

בחנו את לשונית **Details**:

```
URL: https://login-verify-acc0unt.com/auth/microsoft.html
Final URL: https://login-verify-acc0unt.com/auth/microsoft.html
Serving IP: 185.234.72.19
HTTP Status: 200
Body SHA-256: a1b2c3d4e5f6 ...
Body Length: 15,832 bytes
Headers:
  Server: nginx/1.18.0
  Content-Type: text/html; charset=UTF-8
Categories: Phishing, Suspicious
```

שלב 4

בחנו את לשונית **Relations**:

```
Communicating files: 2 files reference this URL
- SHA256: abc123 ... (Trojan.GenericKD.46789012)
- SHA256: def456 ... (PDF/Phishing.Gen)

Downloaded files: 1 file downloaded from this URL
- SHA256: ghi789 ... (HTML/Phishing.Agent)

Contacted domains: 3 domains
- login-verify-acc0unt.com
- cdn-static-assets.com
- tracking-pixel-service.net
```

Contacted IPs: 2 IPs

- 185.234.72.19 (Ukraine)
- 91.215.85.33 (Russia)

Relations מציג את ה"מערכת האקולוגית" של ה-URL — קבצים קשורים, דומיינים ו-IPs. אלו IOCs נוספים לחקירה!

שלב 5

השתמשו ב-VirusTotal API לבדיקה אוטומטית (אופציונלי):

```
# API דרך URL בדיקה
curl -X POST "https://www.virustotal.com/api/v3/urls" \
  -H "x-apikey: YOUR-API-KEY" \
  -d "url=https://suspicious-site.com"

# קבלת תוצאות
curl "https://www.virustotal.com/api/v3/urls/{url-id}" \
  -H "x-apikey: YOUR-API-KEY"
```

חלק ה — Defanging IOCs

שלב 1

Defanging = המרת IOCs לפורמט "לא לחיץ" כדי למנוע לחיצה בטעות.

כללי Defanging סטנדרטיים:

סוג IOC	מקורי	Defanged	כלל
URL (https)	https://evil.com	hxxps://evil[.]com	https→hxxps נקודות→[.]
URL (http)	http://evil.com	hxxp://evil[.]com	http→hxxp נקודות→[.]
Domain	evil.com	evil[.]com	נקודות→[.]

סוג IOC	מקורי	Defanged	כללי
IP Address	185.234.72.19	19[.]72[.]234[.]185	נקודות→[.]
Email	hacker@evil.com	hacker@[.]evil[.]com	@→[.], נקודות→[.]

שלב 2

Defanging באמצעות שורת פקודה:

```
# Bash – defang URL
echo "https://evil-phishing-site.com/login.html" | sed 's/https/hxxps/; s/

# תוצאה: hxxps://evil-phishing-site[.]com/login[.]html

# Bash – defang IP
echo "185.234.72.19" | sed 's/\./[.]/g'
# 19[.]72[.]234[.]185 :תוצאה

# PowerShell – defang URL
"https://evil-phishing-site.com/login.html" -replace 'https','hxxps' -repl
```

שלב 3

Defanging באמצעות Python:

```
#!/usr/bin/env python3
"""IOC Defanger – converts IOCs to safe format"""

def defang_url(url):
    """Defang a URL"""
    result = url.replace('https://', 'hxxps://').replace('http://', 'hxxp:
    result = result.replace('.', '[.]')
    return result

def defang_ip(ip):
    """Defang an IP address"""
```

```

return ip.replace('.', '[]')

def defang_email(email):
    """Defang an email address"""
    return email.replace('@', '[@]').replace('.', '[]')

def refang(text):
    """Reverse defanging - convert back to original"""
    result = text.replace('hxxps://', 'https://').replace('hxxp://', 'http')
    result = result.replace('[]', '.').replace('[@]', '@')
    return result

# דוגמאות
urls = [
    "https://login-verify-acc0unt.com/auth/microsoft.html",
    "http://evil-site.ru/malware.exe",
]
ips = ["185.234.72.19", "91.215.85.33"]
emails = ["hacker@evil-phishing.com"]

print("≡ Defanged IOCs ≡")
for u in urls:
    print(f"URL: {defang_url(u)}")
for ip in ips:
    print(f"IP: {defang_ip(ip)}")
for e in emails:
    print(f>Email: {defang_email(e)}")

```

חלק ו — כתיבת דוח IOC מקצועי

שלב 1

צרו קובץ `ioc_report.txt` עם התכונה הבאה:

```

=====
IOC INVESTIGATION REPORT
=====

```

Date: 2026-04-15
Analyst: [Your Name]
Case ID: PHISH-2026-0415-001
Severity: HIGH
Status: Confirmed Phishing

1. EXECUTIVE SUMMARY

A phishing campaign was detected targeting company employees. The campaign uses a Microsoft login page replica to harvest credentials. The phishing kit is hosted on a recently registered domain in Ukraine.

2. INDICATORS OF COMPROMISE (IOCs)

--- URLs ---

hxxps://login-verify-acc0unt[.]com/auth/microsoft[.]html
hxxps://login-verify-acc0unt[.]com/api/collect[.]php

--- Domains ---

login-verify-acc0unt[.]com
cdn-static-assets[.]com
tracking-pixel-service[.]net

--- IP Addresses ---

185[.]234[.]72[.]19 (AS48693, Ukraine)
91[.]215[.]85[.]33 (AS197695, Russia)

--- Email Addresses ---

security[@]micros0ft-verify[.]com
noreply[@]micros0ft-verify[.]com

--- File Hashes ---

SHA256: a1b2c3d4e5f6 ... (HTML phishing page)
SHA256: ghi789abcdef ... (JavaScript credential stealer)

--- Email Subjects ---

"Action Required: Verify Your Account"

"Your Account Will Be Suspended"

3. ANALYSIS DETAILS

Domain Registration:

Registrar: NameCheap, Inc.
Creation Date: 2026-04-09 (6 days ago)
Expiration: 2027-04-09
Privacy: WhoisGuard enabled

Hosting:

IP: 185.234.72.19
ASN: AS48693 - Rices Privately owned enterprise
Country: Ukraine
Server: nginx/1.18.0

SSL Certificate:

Issuer: Let's Encrypt Authority X3
Valid From: 2026-04-09
Valid To: 2026-07-08

Page Analysis:

- Microsoft login page replica
- Form action: /api/collect.php (credential harvester)
- Hidden campaign field: "ms-april-2026"
- JavaScript keylogger detected
- Microsoft logo downloaded from CDN

Detection Results:

VirusTotal: 12/94 vendors (Phishing)
urlscan.io: Score 85/100 (Potentially Malicious)
Google Safe Browsing: Flagged as Phishing
PhishTank: Listed (ID: 8234567)

4. RECOMMENDATIONS

Immediate Actions:

- [] Block domains/IPs at firewall/proxy
- [] Block sender addresses in email gateway
- [] Search mailboxes for related emails and remove
- [] Reset credentials for any users who clicked

Long-term Actions:

- [] Conduct phishing awareness training
- [] Review Safe Links / URL filtering policies
- [] Add IOCs to SIEM detection rules
- [] Share IOCs with industry ISAC

5. REFERENCES

urlscan.io: [https://urlscan.io/result/abc123-def456 ... /](https://urlscan.io/result/abc123-def456.../)
VirusTotal: [https://www.virustotal.com/gui/url/ ...](https://www.virustotal.com/gui/url/...)
PhishTank: https://phishtank.org/phish_detail.php?phish_id=8234567

END OF REPORT

דוח IOC מקצועי מסכם את כל הממצאים בפורמט מובנה שמאפשר תגובה מהירה.

שלב 2

סקריפט Python ליצירת דוח אוטומטי (אופציונלי):

```
#!/usr/bin/env python3
"""
URL Investigation Script
חשוד URL מבצע חקירה אוטומטית של
"""
import subprocess
```



```

import json
import sys
from datetime import datetime

def investigate_url(url):
    """חקירה אוטומטית של URL"""
    report = {
        "date": datetime.now().strftime("%Y-%m-%d %H:%M"),
        "url": url,
        "findings": {}
    }

    # 1. HTTP Headers
    print("[*] Checking HTTP headers ... ")
    try:
        result = subprocess.run(
            ['curl', '-Is', '-m', '10', url],
            capture_output=True, text=True, timeout=15
        )
        headers = result.stdout
        report["findings"]["http_headers"] = headers
        # Extract status code
        status = headers.split('\n')[0] if headers else "No response"
        print(f"    Status: {status}")
    except Exception as e:
        print(f"    Error: {e}")

    # 2. DNS Resolution
    print("[*] Resolving DNS ... ")
    from urllib.parse import urlparse
    domain = urlparse(url).hostname
    try:
        result = subprocess.run(
            ['nslookup', domain],
            capture_output=True, text=True, timeout=10
        )
        report["findings"]["dns"] = result.stdout
        print(f"    Domain: {domain}")
    except Exception as e:
        print(f"    Error: {e}")

```

```

# 3. WHOIS
print("[*] WHOIS lookup ... ")
try:
    result = subprocess.run(
        ['whois', domain],
        capture_output=True, text=True, timeout=15
    )
    report["findings"]["whois"] = result.stdout
    # Extract creation date
    for line in result.stdout.split('\n'):
        if 'creation' in line.lower():
            print(f"    {line.strip()}")
except Exception as e:
    print(f"    WHOIS not available: {e}")

# 4. Generate defanged IOCs
defanged_url = url.replace('https:// ', 'hxxps:// ').replace('http:// ',
defanged_domain = domain.replace('.', '[.]') if domain else 'N/A'
report["findings"]["defanged"] = {
    "url": defanged_url,
    "domain": defanged_domain
}

# Print summary
print(f"\n{'='*50}")
print("Investigation Summary")
print(f"{'='*50}")
print(f"URL:      {defanged_url}")
print(f"Domain:    {defanged_domain}")
print(f>Date:      {report['date']}")
print(f"\nNext steps:")
print(f"  1. Check on urlscan.io: https://urlscan.io")
print(f"  2. Check on VirusTotal: https://www.virustotal.com")
print(f"{'='*50}")

return report

if __name__ == '__main__':
    if len(sys.argv) < 2:

```

```
print("Usage: python investigate_url.py <URL>")
print("Example: python investigate_url.py https://suspicious-site.")
sys.exit(1)
investigate_url(sys.argv[1])
```

חלק 2 — כלים נוספים לחקירת URLs

כלי	קישור	שימוש	חינמי?
urlscan.io	urlscan.io	סריקת URL, screenshot, DOM analysis	כן (100 סריקות/יום)
VirusTotal	virustotal.com	בדיקה מול 90+ מנועי AV	כן (500 בקשות/יום)
PhishTank	phishtank.org	מאגר URLs פישניג מדווחים	כן
URLhaus	urlhaus.abuse.ch	מאגר URLs של malware	כן
ANY.RUN	any.run	Sandbox אינטראקטיבי	חלקית
Hybrid Analysis	hybrid-analysis.com	Sandbox analysis	כן
Browserling	browserling.com	פתיחת URL בדפדפן מרוחק	חלקית
CheckPhish	checkphish.ai	זיהוי פישניג AI-based	כן

תוצאה צפויה

לאחר השלמת המעבדה תוכלו:

- לחקור URLs חשודים באמצעות `curl`, `whois` ו-`dig`
- להשתמש ב-urlscan.io לסריקה מקיפה (screenshot, DOM, HTTP transactions)
- להשתמש ב-VirusTotal לבדיקת URL מול מנועי AV מרובים
- לבצע Defanging נכון של IOCs
- לכתוב דוח IOC מקצועי ומובנה
- להשתמש בסקריפט Python לחקירה אוטומטית

שאלות לניתוח

1. מדוע חשוב לבצע Defanging ל-IOCs לפני שיתופם בדוח או ב-email? מה הסיכון בלי?
2. URL מציג redirect chain של 4 שלבים — מדוע תוקפים משתמשים ב-redirects מרובים?
3. VirusTotal מציג detections 0/94 עבור URL חשוד — האם זה אומר שהוא בטוח? הסבירו.
4. מהו ההבדל בין urlscan.io ל-VirusTotal? מתי תשתמשו בכל אחד?
5. כיצד Domain Age עוזר בזיהוי דומיינים זדוניים? האם דומיין ותיק תמיד בטוח?
6. תוקף רשם דומיין עם WhoisGuard — האם ניתן לגלות את זהותו? אילו דרכים קיימות?
7. כיצד תבנו Watchlist של IOCs שמתעדכנת אוטומטית דרך APIs?

סיכום

במעבדה זו למדנו כיצד לחקור URLs חשודים באמצעות כלי CLI וכלי OSINT. `curl` מאפשר בדיקת headers ו-redirect chains בבטחה. `whois` ו-`dig` חושפים את תשתית הדומיין. `urlscan.io` מספק screenshot וניתוח DOM מעמיק. VirusTotal בודק מול עשרות מנועי Defanging. AV של IOCs הוא הכרחי לשיתוף בטוח. דוח IOC מובנה מאפשר תגובה מהירה ומתואמת. אנליסט SOC מיומן משלב את כל הכלים הללו בתהליך חקירה שיטתי.